

NGCSECURITY

PENTEST ANALYSIS & PLANNING

Propuesta de abordaje para Aurora Market

Organización	Aurora Market
Responsable	Alondra Juliana Gadea
Actividad	Actividad 01 · Pentest Analysis & Planning
Modalidad prevista	Grey Box
Curso	Ethical Hacking - Hacker Women Council
Estado	Planificación previa a pruebas técnicas

ALCANCE DEL DOCUMENTO

Este documento no contiene pruebas ejecutadas, vulnerabilidades encontradas ni resultados de explotación. Su propósito es describir cómo se planificaría la evaluación: qué se analizaría, con qué herramientas, en qué horarios, con qué objetivo y por qué cada decisión tendría sentido para Aurora Market.



Índice

1. Objetivo de realizar el pentest	3
2. Alcance y condiciones de trabajo	4
3. Recopilación de información	5
4. Horarios propuestos	6
5. Plan técnico por fases	6
6. Herramientas propuestas	9
7. Resultado esperado de la planificación	10

CRITERIO DE LA ACTIVIDAD

La propuesta se redacta en futuro y en modo condicional. Las acciones descritas corresponden a decisiones previas al pentest. Cualquier vulnerabilidad, severidad, impacto o evidencia solo podría establecerse después de una ejecución autorizada.

Objetivo concreto para Aurora Market

Aurora Market es una plataforma de comercio electrónico que procesa información de clientes, pedidos, autenticación de usuarios y operaciones asociadas al proceso de compra. Por esta razón, una evaluación de seguridad permitiría conocer qué tan expuesta se encuentra la plataforma frente a errores de configuración, fallas de control de acceso, problemas de autenticación, vulnerabilidades web o debilidades en la interacción entre el frontend y la API.

El pentest se plantearía como una evaluación controlada cuyo objetivo principal sería obtener una visión técnica del nivel de seguridad de los componentes incluidos en el alcance antes de que una debilidad pueda ser aprovechada de forma maliciosa. No se buscaría únicamente detectar problemas, sino comprender qué superficies de ataque existen, qué controles están implementados, cómo se comportan ante distintos escenarios y qué áreas merecen una revisión prioritaria.

El caso de Aurora Market incluye un reporte previo de un usuario que habría visualizado información perteneciente a otra cuenta. Este dato serviría como punto de partida para decidir qué controles convendría analizar con mayor profundidad, especialmente los relacionados con autorización y acceso a recursos. Sin embargo, en esta etapa ese reporte se trataría solamente como una referencia para orientar la planificación. No se asumiría que existe una vulnerabilidad ni se definiría su tipo hasta realizar las pruebas correspondientes.

Para el cliente, el valor de esta evaluación estaría en contar con información técnica que permita tomar decisiones antes de que un incidente se convierta en un problema mayor. El pentest podría ayudar a priorizar mejoras, identificar controles que necesiten fortalecerse, reducir el riesgo asociado a datos personales y operaciones de compra, y generar una base para futuras correcciones y revisiones de seguridad.

Además, la evaluación permitiría observar la seguridad desde la perspectiva de distintos perfiles autorizados. Al tratarse de una modalidad Grey Box, se dispondría de información y cuentas de prueba limitadas, lo que permitiría analizar tanto la exposición externa de la plataforma como determinados comportamientos accesibles para usuarios autenticados.

PREGUNTA QUE GUIARÍA LA EVALUACIÓN

¿Qué tan resistente es Aurora Market frente a accesos no autorizados, errores de configuración y vulnerabilidades web dentro de los módulos definidos, y qué controles deberían revisarse o fortalecerse según la evidencia que se obtenga durante el pentest?



Alcance propuesto

Antes de comenzar cualquier actividad técnica, propondría validar con Aurora Market qué activos pueden evaluarse, qué cuentas se utilizarán, qué pruebas se encuentran permitidas y cuáles quedan expresamente excluidas. Esto evita afectar sistemas de terceros o ejecutar acciones que el cliente no haya autorizado.

Activos previstos	Plataforma web de Aurora Market y subdominios principales autorizados.
Módulos	Login, búsqueda de productos, carrito de compras, proceso de pago, consulta de pedidos y panel de administración para empleados.
Cuentas de prueba	1 cuenta de cliente estándar y 1 cuenta de empleado con permisos limitados.
Modalidad	Grey Box: acceso parcial a información y credenciales de prueba proporcionadas por el cliente.
Fuera de alcance	Redes sociales corporativas, equipos personales, correos externos, proveedores de pago y servicios de terceros.
Pruebas excluidas	DoS, DDoS, fuerza bruta intensiva y acciones que puedan degradar la disponibilidad de la plataforma.

Condiciones previas

También propondría definir un contacto técnico responsable durante la ventana de pruebas, un procedimiento para detener actividades si se observa degradación del servicio y un canal para reportar inmediatamente cualquier comportamiento inesperado. Estas decisiones forman parte de la planificación porque una evaluación profesional no depende solo de herramientas: también requiere reglas claras de operación.



Fuentes que utilizaría

La recopilación de información combinaría fuentes abiertas (OSINT) y fuentes internas autorizadas. Utilizar ambas permitiría obtener contexto sin depender exclusivamente de lo que expone Internet ni de la información entregada por el cliente.

Fuentes abiertas (OSINT)

Utilizaría OSINT para conocer qué información pública existe sobre los activos de Aurora Market antes de realizar interacción activa. Buscaría identificar dominios y subdominios relacionados, registros DNS, certificados públicos, tecnologías visibles, servicios publicados y cualquier referencia técnica que ayude a construir un inventario inicial de la superficie expuesta.

Podría apoyarme en búsquedas web, consultas DNS, información de certificados y plataformas como Shodan. El objetivo sería obtener contexto: por ejemplo, detectar si existe un subdominio destinado a una API, qué servicios aparecen asociados a un host o qué tecnología podría estar utilizando la aplicación.

Fuentes internas

Como parte del enfoque Grey Box, solicitaría o utilizaría únicamente la información que Aurora Market decida proporcionar: cuentas de prueba, roles disponibles, módulos incluidos en el alcance, dominios autorizados y, si existiera, documentación básica de la aplicación. Esta información serviría para comprender qué flujos deberían revisarse y qué diferencias existen entre un cliente y un empleado.

Cómo organizaría la información

La información obtenida se registraría en una matriz de activos y puntos de interés. Allí anotaría el host o módulo, la fuente de la información, el servicio o tecnología observada, su relación con el alcance y qué revisión técnica podría corresponder después. De esta manera, el reconocimiento no sería una colección de datos sueltos, sino una base para decidir qué analizar en las siguientes fases.



Ventana de trabajo

Aurora Market indica que las actividades deberían realizarse durante horarios de menor operación. Tomando como referencia las 18:30, propondría una ventana principal de pruebas entre las 18:30 y las 22:00 horas, sujeta a confirmación del cliente.

Elegiría esta franja porque permite disminuir la posibilidad de afectar a una gran cantidad de usuarios reales y, al mismo tiempo, mantener una ventana razonable para que exista personal técnico disponible si fuera necesario detener una prueba o revisar un comportamiento inesperado.

No todas las tareas necesitarían ejecutarse dentro de esa franja. La recopilación pasiva de información, la preparación de casos de prueba, el análisis de resultados ya obtenidos y la redacción del informe podrían realizarse fuera de la ventana porque no generan interacción significativa con la plataforma.

Las pruebas activas que generen mayor cantidad de solicitudes se programarían dentro de la ventana acordada y se ejecutarían de forma gradual. Si una técnica pudiera producir una carga considerable, propondría validarla previamente con el cliente o reemplazarla por una alternativa menos invasiva.



5.1 Reconocimiento

Qué analizaría: la superficie de ataque visible de Aurora Market, los hosts autorizados, posibles subdominios, servicios accesibles, rutas de la aplicación, endpoints, parámetros, formularios, cookies, cabeceras y mecanismos de sesión.

Cómo lo haría: comenzaría con OSINT y luego realizaría reconocimiento activo limitado sobre los activos autorizados. Utilizaría Nmap para conocer qué puertos y servicios están accesibles y OWASP ZAP o Burp Suite para observar cómo se comunica la aplicación y construir un mapa de sus rutas y solicitudes.

Para qué: el reconocimiento permitiría responder qué componentes están expuestos y dónde existen puntos de entrada que merecen análisis posterior. Un puerto abierto, por ejemplo, no se consideraría por sí mismo una vulnerabilidad; serviría para saber qué servicio existe y decidir si corresponde revisarlo.

Qué buscaría conocer antes de avanzar: qué servicios forman parte del entorno, qué roles existen, cómo se gestionan las sesiones, qué parámetros controla el usuario, qué endpoints utiliza la API y qué diferencias se observan entre las funciones disponibles para las cuentas de prueba.

5.2 Análisis de vulnerabilidades

Qué analizaría: los componentes identificados durante el reconocimiento, buscando indicadores de configuraciones inseguras, controles de acceso débiles, problemas de autenticación, exposición de información, validación insuficiente de entradas, manejo de errores, cabeceras de seguridad y protecciones frente a solicitudes repetidas.

Herramientas: utilizaría OWASP ZAP como apoyo automatizado para revisar el tráfico y detectar posibles indicadores en la aplicación web, y Burp Suite para realizar una revisión manual más detallada de solicitudes, respuestas, parámetros y lógica de negocio. Las herramientas automatizadas serían un punto de apoyo, no una fuente automática de conclusiones.

Qué información buscaría obtener: una lista de comportamientos o configuraciones que requieran validación posterior. Por ejemplo, si una solicitud contiene un identificador de recurso, analizaría cómo se utiliza y si el servidor parece aplicar controles de autorización. En esta etapa lo registraría como un punto de revisión, no como una vulnerabilidad confirmada.

Propósito: priorizar qué casos de prueba deberían ejecutarse después, evitando realizar pruebas innecesarias y enfocando la evaluación en aquello que tenga relación con la superficie observada y con el escenario de Aurora Market.

5.3 Explotación

En la planificación de esta fase definiría cómo se validarían, de manera controlada, los posibles problemas identificados previamente. Todavía no ejecutaría la explotación ni asumiría que alguna vulnerabilidad existe.

Qué propondría hacer: diseñar casos de prueba concretos para cada hipótesis. Si, por ejemplo, durante el análisis se detectara un parámetro relacionado con pedidos o perfiles, prepararía una prueba para comprobar si el backend verifica correctamente los permisos asociados a ese recurso utilizando únicamente cuentas y datos de prueba autorizados.

Con qué herramientas: principalmente Burp Suite para modificar solicitudes de forma controlada y comparar el comportamiento del servidor. Para otros casos podría utilizar OWASP ZAP u otras herramientas específicas según el tipo de prueba que surja del análisis.

Por qué: la explotación debería servir únicamente para confirmar o descartar una hipótesis y comprender su posible impacto. No se buscaría ampliar innecesariamente el acceso, alterar datos reales ni mantener persistencia.

5.4 Post-explotación

La fase de post-explotación también se definiría de antemano, pero solo tendría sentido si durante el pentest se confirmara una vulnerabilidad. En esta actividad no se ejecutaría.

Qué analizaría si fuera necesaria: hasta dónde podría llegar el acceso obtenido, qué tipo de información podría verse afectada, qué nivel de privilegio sería requerido y si el problema se encuentra limitado a un módulo o podría impactar otros componentes.

Límites: utilizaría la mínima cantidad de datos necesaria para demostrar el impacto, preferentemente información perteneciente a cuentas de prueba. No propondría persistencia,

extracción masiva de información ni acciones destructivas.

5.5 Informe

La etapa de informe se planificaría desde el comienzo porque define qué evidencia será necesario registrar durante las pruebas. El objetivo sería entregar a Aurora Market un documento que permita comprender qué se evaluó, cómo se realizó la evaluación y qué resultados fueron efectivamente confirmados.

Qué incluiría: resumen ejecutivo, alcance, metodología, ventanas de prueba, limitaciones, activos evaluados, hallazgos confirmados si los hubiera, evidencia técnica, impacto, nivel de riesgo y recomendaciones de remediación.

Cómo diferenciaría la información: separaría claramente vulnerabilidades confirmadas, observaciones, falsos positivos y pruebas que no hayan podido completarse. Esto evitaría presentar una sospecha como si fuera un resultado comprobado.

Valor para el cliente: el informe permitiría priorizar correcciones y comprender qué riesgos requieren atención primero. También propondría un retest posterior para verificar si las medidas implementadas solucionan los problemas que eventualmente se hayan encontrado.



Herramientas y propósito dentro del plan

OSINT / DNS / certificados	Recopilar información pública sobre dominios, subdominios y tecnologías.	Permite obtener contexto y construir una primera superficie de ataque con mínima interacción.
Shodan	Consultar servicios que aparecen públicamente asociados a activos autorizados.	Complementa el reconocimiento pasivo y ayuda a detectar puntos que convendría validar después.
Nmap	Analizar puertos y servicios accesibles en hosts autorizados.	Permite conocer qué servicios forman parte de la superficie expuesta y decidir cuáles requieren revisión.
OWASP ZAP	Mapear la aplicación, observar tráfico HTTP y apoyar el análisis de configuraciones y posibles indicadores.	Es útil como apoyo automatizado y proxy durante el reconocimiento y el análisis web.
Burp Suite	Interceptar y comparar solicitudes, parámetros, sesiones y respuestas.	Permite diseñar pruebas manuales y estudiar controles de autorización y lógica de negocio.
Revisión manual	Interpretar el comportamiento de la aplicación y validar el contexto de los resultados.	Reduce falsos positivos y permite relacionar la evidencia con el funcionamiento real de Aurora Market.



Qué debería quedar definido antes de comenzar

Al finalizar esta etapa de análisis y planificación, todavía no debería existir una lista de vulnerabilidades encontradas. Lo que sí debería existir es un plan claro y justificable para comenzar la evaluación de forma ordenada.

Antes de ejecutar el pentest esperarías tener definido:

- Qué activos y módulos están autorizados y cuáles quedan fuera de alcance.
- Qué información se recopilará mediante OSINT y qué información será proporcionada internamente.
- Qué herramientas se utilizarán en cada fase y cuál es el propósito de cada una.
- Qué puertos, servicios, rutas, endpoints y mecanismos de autenticación o autorización se buscará conocer durante el reconocimiento.
- Qué tipos de pruebas se prepararán para el análisis de vulnerabilidades y bajo qué condiciones se validarían posteriormente.
- Qué ventana horaria se utilizará para las acciones activas y qué procedimiento se seguirá si se detecta impacto en el servicio.
- Qué evidencia será necesario registrar para construir el informe final.

CONCLUSIÓN

La Actividad 01 se plantea como una etapa de toma de decisiones previa a la ejecución técnica. Para Aurora Market, la planificación permitiría orientar el pentest hacia los riesgos más relevantes sin asumir resultados de antemano. La propuesta define qué se analizaría, qué herramientas se utilizarían, cómo se recopilaría la información, cuándo se realizarían las pruebas y por qué cada decisión resulta adecuada para el escenario.

NGCSECURITY

Actividad 01 · Pentest Analysis & Planning

Documento académico de planificación previa. No contiene resultados de pruebas técnicas.